

Aula 2 (Módulo 10) — Investigações Simuladas de EDR

Diferente da simulação de `ALERTA #00X` do Módulo 08 (que é propositalmente aberta, sem resposta escrita, para você praticar ao vivo), esta aula percorre **cinco cenários já resolvidos**, passo a passo — o objetivo aqui é te mostrar **como raciocinar** usando as cinco dimensões de telemetria da Aula 1, para depois você aplicar esse mesmo raciocínio nas suas próprias investigações ao vivo.

Cenário 1 — PowerShell suspeito

Telemetria observada:

```
Process tree: outlook.exe → powershell.exe
Command line: powershell.exe -nop -w hidden -enc SQBFAFgA...
Arquivo: nenhum arquivo criado por esse processo até o momento
Registry: nenhuma modificação
Rede: conexão de saída para 185.220.101.47:443 (IP sem reputação conhecida)
```

Raciocínio:

1. **Process tree:** `outlook.exe` como pai de `powershell.exe` já é anômalo — Outlook não deveria, no uso normal, abrir um interpretador de comandos (mesmo padrão que vimos com Word, Módulo 02, Aula 5, agora com outra aplicação do Office).
2. **Command line:** `-nop` (no profile — inicia mais rápido e sem carregar configurações do usuário), `-w hidden` (sem janela visível), `-enc` (comando codificado em Base64) — três flags que, juntas (Módulo 02, Aula 2), formam um padrão de alta suspeita.
3. **Rede:** conexão de saída logo em seguida, para um IP externo sem reputação conhecida — consistente com o segundo estágio de um malware entrando em contato com C2.

Conclusão: True Positive, severidade Alta. A cadeia completa (aplicação de e-mail → PowerShell ofuscado oculto → conexão externa) é consistente com execução de payload malicioso via e-mail (phishing). **Ação:** isolar o host (Aula 1 mencionou que EDR tem capacidade de resposta), decodificar o Base64 para entender o que o script realmente faz, verificar o e-mail de origem no Outlook.

Cenário 2 — Execução de binário desconhecido

Telemetria observada:

```
Process tree: chrome.exe → explorer.exe → fatura_setembro.exe
Command line: fatura_setembro.exe (sem argumentos)
Arquivo: fatura_setembro.exe foi criado em C:\Users\ana\Downloads\
          2 minutos antes de ser executado
Hash: não encontrado em nenhuma base de reputação conhecida
Rede: sem conexão de rede até o momento
```

Raciocínio:

1. **Process tree:** o caminho `chrome.exe → explorer.exe → binário` é o padrão **normal** de alguém baixando um arquivo pelo navegador e depois clicando duas vezes nele no Explorer — não é, por si só, uma cadeia anômala (diferente do Cenário 1).
2. **Nome do arquivo + contexto:** `fatura_setembro.exe` é um nome típico de engenharia social (disfarçado de documento/fatura, mas com extensão `.exe`) — um padrão clássico de phishing com anexo executável.
3. **Hash desconhecido:** não estar em nenhuma base de reputação **não prova** nada sozinho (poderia ser um software legítimo raro), mas **soma** suspeita quando combinado com os outros dois pontos.
4. Ainda não há conexão de rede nem atividade de arquivo/registry **registrada** — mas isso pode significar que o processo ainda não teve tempo de agir, não que é seguro.

Conclusão: Suspeito o suficiente para conter primeiro e investigar depois (severidade Alta por precaução, mesmo com confiança ainda moderada — lembra da diferença entre severidade e confiança, Módulo 08, Aula 2). **Ação:** isolar o host imediatamente (interrompe qualquer próximo passo antes que aconteça), enviar o arquivo para análise (Módulo 20 — Malware Analysis), calcular o hash e comparar com bases de reputação de novo depois (pode ser reconhecido depois de análise automatizada, mesmo que não estivesse na base local no momento).

Cenário 3 — Processo filho incomum

Telemetria observada:

```
Process tree: sqlservr.exe (SQL Server) → cmd.exe → net.exe user
```

Raciocínio:

1. `sqlservr.exe` é o processo do próprio motor do banco de dados — **não deveria**, em uso normal, gerar processos filho de shell.
2. `cmd.exe → net.exe user` é um comando de **enumeração** — lista contas de usuário do sistema, um passo comum de reconhecimento pós-exploração (o atacante querendo saber quais contas existem para tentar escalar privilégio ou se mover lateralmente).
3. Esse padrão é consistente com **exploração de uma vulnerabilidade na própria aplicação de banco de dados** — muitas explorações contra servidores SQL conseguem executar comandos do sistema operacional através de funcionalidades da própria aplicação (ex.: histórico de vulnerabilidades em stored procedures como `xp_cmdshell`, quando habilitadas sem necessidade).

Conclusão: True Positive, severidade Crítica (servidor de banco de dados é tipicamente um ativo de alta criticidade — Módulo 08, Aula 2). **Ação:** isolar imediatamente, revisar logs do SQL Server para encontrar a query/conexão que originou isso, verificar se `xp_cmdshell` (ou equivalente) está habilitado sem necessidade.

Cenário 4 — Persistência

Telemetria observada:

```
Registry: nova entrada criada em
HKCU\Software\Microsoft\Windows\CurrentVersion\Run
Nome: "WindowsUpdateHelper"
Valor: C:\Users\ana\AppData\Roaming\svhost.exe
Processo que fez a escrita: powershell.exe (o mesmo do Cenário 1,
minutos depois)
```

Raciocínio:

1. Lembra da Run key do Módulo 02, Aula 1? Isso é exatamente **persistência via Registry** (T1547.001) sendo criada em tempo real.
2. O nome "WindowsUpdateHelper" é uma tentativa de **disfarce** — soa como algo legítimo do Windows.
3. O caminho do executável (`svhost.exe` , sem o "c" de `svchost.exe` — um typosquatting de nome de processo) é outro sinal de disfarce deliberado, tentando passar despercebido em uma checagem rápida.
4. Isso continua a cadeia do Cenário 1 — o mesmo `powershell.exe` suspeito agora está se estabelecendo para sobreviver a um reboot.

Conclusão: True Positive, confirma o Cenário 1 como incidente real, não isolado. Ação: remover a chave de Registry, remover o arquivo `svhost.exe` , e — importante — não considerar isso resolvido só removendo esses dois itens: é preciso investigar o que mais aquele PowerShell pode ter feito antes de ser contido (Módulo 15, Incident Response).

Cenário 5 — Conexão suspeita

Telemetria observada:

```
Processo: backup_agent.exe (processo legítimo de backup, já instalado
há meses, hash conhecido e confiável)
Rede: conexão de saída às 3h47 da manhã para um IP na Rússia, porta
4444, transferindo 2,3 GB de dados em 40 minutos
```

Raciocínio:

1. Diferente dos outros cenários, aqui o **processo em si é legítimo e confiável** — a suspeita vem inteiramente do **comportamento de rede**: horário incomum (3h47), porta atípica para esse tipo de processo (4444 é historicamente associada a ferramentas ofensivas, embora isso sozinho não seja definitivo), e principalmente o **volume de dados** (2,3 GB é muito para um processo de backup que, nesse ambiente, normalmente só sincroniza configurações pequenas).
2. Isso ilustra um ponto importante: **um processo confiável pode ser abusado** — seja porque foi comprometido (o binário legítimo foi substituído ou injetado com código malicioso), seja porque um atacante está literalmente usando aquele canal de rede já permitido pelo firewall (Módulo 03, Aula 6) para disfarçar exfiltração.

Conclusão: True Positive, forte indício de exfiltração de dados. Ação: isolar a rede desse host imediatamente (interromper a transferência em andamento, se ainda estiver ocorrendo), verificar a integridade do binário `backup_agent.exe` (hash confere com a versão oficial do fabricante?), identificar **o quê** foi transferido.

Padrão comum entre os cinco cenários

Nenhuma conclusão veio de UMA SÓ dimensão de telemetria.
Sempre foi a COMBINAÇÃO: process tree + command line + arquivo + registry + rede, junto com CONTEXTO (criticidade do ativo, horário, o que é "normal" para aquele processo/usuário específico).

Isso é o núcleo da habilidade de investigação que estamos construindo desde o Módulo 08 — e vale reforçar: cada um desses cinco cenários é uma variação de técnicas que já vimos, catalogadas no MITRE ATT&CK (que formalizamos no Módulo 13). Reconhecer esse tipo de padrão vai ficando mais natural com prática — que é exatamente para o que servem as simulações ao vivo de `ALERTA #00X` (Módulo 08, Aula 3).

Recapitulando o Módulo 10

- EDR complementa o SIEM com telemetria profunda e correlacionada em um único host: process tree, command line, arquivo, registry, rede.
- Nenhuma decisão de TP/FP deveria vir de uma única dimensão isolada — sempre combine as cinco, junto com contexto (criticidade, horário, "normal" esperado).
- Mesmo processos legítimos e confiáveis podem ser abusados — a suspeita, nesses casos, vem do comportamento (volume, horário, porta atípica), não da identidade do processo.

Módulo 10 concluído. 🎉

Próximo módulo

Módulo 11 — Sysmon: vamos aprofundar de verdade a ferramenta que alimenta boa parte dessa telemetria em ambientes Windows — instalação, configuração, e cada Event ID relevante com exercício próprio.

Fontes recomendadas

- **MITRE ATT&CK — T1547.001, T1059.001, T1543, T1078 (Valid Accounts):** técnicas relacionadas aos padrões discutidos nos cinco cenários. <https://attack.mitre.org/techniques/T1547/001/>
- **MITRE ATT&CK — T1041 (Exfiltration Over C2 Channel):** técnica oficial relacionada ao Cenário 5. <https://attack.mitre.org/techniques/T1041/>